

Evaluating Bias, Trustworthiness and Fairness in Open-Source Large Language Models

Context: Users Susceptible to Phishing and Phishing Victims

Joel Jorly Student ID: a1959854

Advanced Topics in Artificial Intelligence and Machine Learning, Adelaide University, April 2026

Abstract. This report looks at bias, trustworthiness, and fairness in fifteen open-source LLMs served through five inference providers, using phishing susceptibility as the test setting. Using two prompts from Trepas (2026) alongside the DECODINGTRUST framework (Wang et al., 2024), I gathered 840 persona-level responses, then checked whether the demographic profiles the models tagged as most vulnerable lined up with the evidence-based risk factors reported by Sarker et al. (2023). The clearest result is gender bias: $\text{Chi}^2 = 66.542$ ($p < 0.0001$), where non-binary personas were flagged 61.3% of the time, compared with 18.6% for male personas. Age bias pointed the opposite way of the literature ($t = -3.693$, $p = 0.0002$). Membership in the IT domain was generally protective ($\text{OR} = 0.611$, $p = 0.019$), though Cerebras flipped that pattern ($\text{OR} = 10.636$). Across ten repeated runs, nine of thirteen valid models stayed above 70% consistent, and three were exactly 100%, which suggests the vulnerability labels are being produced from stable stereotypes more than from careful reasoning. Coding a 25% subsample supports that reading, since models repeatedly defend their selections by leaning on demographic stand-ins. The report closes by proposing three mitigations.

1 Introduction

Phishing is still one of the stubborn problems in cybersecurity, and lately there's been more curiosity about putting LLMs to work in awareness training and phishing-risk profiling. But curiosity isn't the same as suitability. The real issue is whether these models can judge risk without slipping into shortcuts. When a model keeps flagging particular demographic groups as "high risk" no matter what the individual details look like, that isn't risk assessment at all, it's stereotype reproduction, and that creates a fairness problem and a security problem at the same time.

This report takes that issue up through the ARTI 6000 assignment (Trepas, 2026). The brief calls for three things: seeing how LLM bias shows up in sensitive use cases, using empirical techniques drawn from peer-reviewed work to measure it, and proposing workable mitigations. Those aims line up with the course learning outcomes as well, CLO 1 (analyse advanced AI and ML systems), CLO 2 (engage with relevant literature), and CLO 3 (identify ethical, societal, and technological risks and propose mitigations). Framed through DECODINGTRUST (Wang et al., 2024), the parts that matter most for this work are stereotype bias, fairness, and machine ethics.

- RQ1. Do open-source LLMs assign phishing vulnerability labels in ways that track demographic characteristics rather than individual risk factors?
- RQ2. How stable is that pattern across repeated runs of the same prompt, and does it differ across providers?
- RQ3. What do the models' own justifications reveal about which stereotypes are at work, and what can practically be done about them?

To examine those areas, I gathered 840 persona-

level outputs from fifteen models, spread across five providers (Groq, HuggingFace, OpenRouter, Cerebras, and NVIDIA) using the two prompts shown on slide 149 of Trepas (2026). For each persona set, Prompt 2 was run ten times, following the slide 149 guidance to repeat runs so the analysis doesn't hinge on a single random sample. The demographic factors included (age, educational qualification, personality traits, devices, years of experience, domain of work, location, and gender) align with the variables listed on slide 150 of Trepas (2026) and with the individual human factors described in Sarker et al. (2023).

If a tool repeatedly scores non-binary users or younger workers as the highest-risk group, it ends up concentrating training and interventions on those people while missing individuals who are actually at risk. That's an ethical issue, but it's also a straightforward operational security failure, and it's the kind of thing you only catch when you test for it.

2 Literature Review

2.1 DECODINGTRUST

In Wang et al. (2024), the authors put together a wide-ranging evaluation setup for LLM trustworthiness, laid out across seven dimensions: toxicity, stereotype bias, adversarial robustness, privacy and security, factuality, fairness, and machine ethics. A key result, and one that matters directly here, is that stereotype bias in strongly aligned models such as GPT-4 doesn't shift much just because you reword the prompt. In plain terms, once a model has linked a demographic group with "vulnerability," swapping phrasing around usually won't undo that link.

Their fairness lens is also relevant. It asks a specific question: if you keep everything in a prompt the same but replace demographic identifiers, do the outputs change in a consistent, systematic way? That's the same basic

idea I follow, but I apply it in a tighter, more controlled form, the prompt stays fixed while persona demographics change naturally across 840 responses.

Trepa (2026) describes the bigger pattern as “bias laundering,” meaning human bias in the training text gets replicated and spread through ML systems at scale. Those notes separate intrinsic bias, which sits inside the model’s internal representations, extrinsic bias, which shows up in what the model actually says, and application bias, which is what happens once the system is deployed in real settings. What I measure here is extrinsic bias, it’s the part that directly affects anyone thinking about using these models.

2.2 Phishing Susceptibility

Sarker et al. (2023) surveyed 69 papers on anti-phishing interventions and pulled out 22 recurring factors tied to susceptibility, with 15 of them being individual-level human factors. Several matter especially for this work. Age (D1) is associated with higher risk, particularly among users aged 18–25. Educational qualification (D6) works in the other direction, postgraduate users report more confidence in spotting attacks. Complacency (D2) and curiosity (D4) show up as risk factors too, and optimism bias (D12) can lead people to underestimate their own exposure. Lack of knowledge (D18) appears in twenty of the 69 studies, making it the most consistently supported technical factor in that review.

On the domain side, an IT background tends to be protective. And guideline G16 in Sarker et al. (2023) argues against blanket interventions, instead it recommends tailoring to demonstrated individual need. That’s effectively the bar I’m using for these models: do they respond to individual differences, or do they slide back into broad group stereotypes?

2.3 Bias in LLMs

Navigli et al. (2023) lay out the main bias pathways in LLMs, from problems in training data all the way to stereotype reproduction at the output stage. They point out why this is difficult to “fix” in the usual way, it isn’t a single defect so much as a reflection of patterns in human writing that the model then reinforces. Bender et al. (2021) argue that large language models trained on web-scale data inevitably encode and amplify the biases present in that data, making bias an architectural property rather than a correctable defect. Ouyang et al. (2022) adds another twist: alignment through RLHF can reduce certain biases, but it can also create fresh ones, depending on the values and judgments of the annotators. Since every model in this study is instruction-tuned or RLHF-aligned, what comes out reflects both pretraining patterns and whatever the annotation process added.

2.4 What This Study Adds

A lot of LLM bias work has centered on toxicity detection, sentiment analysis, or coreference resolution (Navigli et al., 2023; Wang et al., 2024). Taking those evaluation ideas into a phishing vulnerability setting is less common. Here, Sarker et al. (2023) provides an empirical baseline for which demographic factors truly

relate to phishing risk, and the question is whether the models have learned those same relationships, or whether they’ve learned something else. Running the same evaluation across five providers, not just one, is a deliberate extension too, it helps show whether any bias patterns are widespread across the open-source environment or mostly tied to specific model families.

3 Methodology

3.1 Model and Provider Selection

Following slide 148 of Trepa (2026), I picked fifteen models spread across five different providers, three per provider, aiming for the 800–1000 sample target. The final dataset landed at 840 rows, which sits comfortably inside the range Trepa (2026) calls for. The choice to go with five providers, instead of pulling five models from a single vendor, was deliberate. I wanted to contrast alignment decisions across separate training lineages, not just compare smaller and larger versions of the same production pipeline. The model set also spans a wide size range, from Llama 3.1 8B up to NVIDIA Nemotron Super 120B, which helps reduce the risk that any result is tied to one specific architecture. Table 1 contains the full breakdown.

Table 1: Providers, models, and row counts.

Provider	Models	Rows
Groq	Llama 3.1 8B; Llama 3.3 70B; GPT-OSS-120B ^a	120
HuggingFace	Llama 3.1 8B; Qwen2.5 32B; Gemma 3 27B	210
OpenRouter	Llama 3.1 8B; Qwen2.5 7B; GPT-OSS-120B	180
Cerebras	Llama 3.1 8B; Qwen 235B; GPT-OSS-120B ^b	120
NVIDIA	Llama 3.1 70B; Llama 3.3 70B; Nemotron Super	210
Total	15 registered (13 with valid data)	840

^a Empty P1 responses; no data collected.

^b 404 during verification; excluded.

3.2 Prompts and Data Collection

Both prompts were taken directly from slide 149 of Trepa (2026). Prompt 1 has the model produce three personas that are demographically diverse, specifying age, educational qualification, personality traits, devices, work experience, domain of work, country, and gender. I added one extra instruction about domain diversity, because without it the personas often collapsed into three technology-adjacent jobs, and that would have made the domain-based analysis pointless. Prompt 2 then asks the model to choose which of the personas would be most vulnerable to phishing, and to explain the choice.

In line with slide 149, Prompt 2 was repeated ten times for each persona set. Temperature was kept at 0.8 for every run, low enough that answers stayed readable, but high enough that a model actually weighing individual characteristics should still show meaningful run-to-run variation. I parsed the outputs using regex to populate

the columns listed on slide 151 of Tropa (2026), including model, provider, run IDs, all persona fields, the reasoning passage, and the final Y/N vulnerability label. Results were written to the Excel file at the end of each provider batch, so a failure mid-run would not wipe out the entire collection.

3.3 Statistical Analysis

Using the slide 152 examples as a template, I ran three statistical checks. First, a **Chi-Square test** on gender to see whether vulnerability labels were evenly distributed across Male, Female, and Non-binary personas. Second, an **independent samples t-test** on age to compare the mean age of personas labelled vulnerable versus non-vulnerable. Third, a **Fisher’s exact test** on whether being in the IT domain was associated with being labelled vulnerable, interpreting an odds ratio below 1.0 as a protective association. Each test was run once on the full 840-row dataset, and then rerun separately within each provider. That per-provider split goes beyond what slide 152 explicitly lays out, but it turned out to matter, the Cerebras effect disappears when everything is pooled.

3.4 Consistency and Qualitative Analysis

To keep a clean measure of consistency, I also logged which persona each model selected in each of the ten Prompt 2 repeats, then computed the share of repeats that matched, averaged across both Prompt 1 persona sets. If a model reaches 100% agreement at temperature 0.8, that is a strong signal it is not responding to persona-specific attributes so much as making a fixed demographic choice and repeating it.

For the qualitative portion, I drew a simple random 25% sample of the vulnerability explanations, 59 out of 236, and coded each text against six themes adapted from Sarker et al. (2023): unfamiliarity with technology, explicit mentions of age, personality traits, work domain, low education, and explicit mentions of gender. The random seed was set to 42 so the sample is reproducible, matching the recommendation on slide 152 of Tropa (2026).

4 Results

4.1 Overall Vulnerability Rates

Out of 840 personas, 236 were tagged as vulnerable, that works out to 28.1%. If the models were basically picking at random among three personas, you would expect 33.3%. None of the providers reached that baseline. Groq landed nearest at 32.5%, followed by Cerebras at 30.8%, NVIDIA at 29.5%, HuggingFace at 26.7%, and OpenRouter at 23.3%. When every provider misses the same benchmark in the same downward direction, “just chance” stops being a convincing story.

4.2 Gender

The overall association is strong, $\text{Chi}^2 = 66.542$ with $p < 0.0001$ and $df = 2$. Gender differences were especially sharp: non-binary personas were flagged 61.3% of the time (49/80), female personas 32.8% (105/320), and male personas only 18.6% (82/440). That leaves a 42-point spread between non-binary and male. Sarker

et al. (2023) do mention gender as a phishing-related factor, but in their framing it connects to demonstrated individual need, not to an identity label by itself. What’s happening here is not that, non-binary identity alone is being treated as a vulnerability cue. Four of the five providers show this pattern at $p < 0.0001$. OpenRouter is the outlier ($p = 1.000$), which points to its free-tier models having alignment steps that muted demographic stereotyping.

4.3 Age

$t = -3.693$ with $p = 0.0002$ for age. Personas labelled vulnerable averaged 35.6 years, while the non-vulnerable group averaged 38.8. The models are treating younger people as more exposed, which goes against Sarker et al. (2023), where older age is the risk direction because of lower digital literacy (D1, D18). The qualitative evidence in Section 4.6 makes the cleaner explanation indirect: the younger personas in this dataset were more often given traits like curiosity and overconfidence, and the models appear to be reacting to those traits, not to age as a standalone variable.

4.4 Domain and Education

Across providers, the overall Fisher’s exact result for IT work was $\text{OR} = 0.611$, $p = 0.019$. IT workers were less likely to be labelled vulnerable, matching Sarker et al. (2023). Cerebras, though, went the other way entirely, $\text{OR} = 10.636$ with $p < 0.0001$, meaning those models were more likely to pick IT personas as vulnerable than any other group. The qualitative coding suggests a reason: the Cerebras models read technical knowledge as a complacency cue (D2), flipping expertise from a shield into a liability. NVIDIA sat at the opposite pole, with $\text{OR} \approx 0$, it essentially never selected IT personas.

Education mostly tracked prior work, but not perfectly. High school was highest on the vulnerability scale at 44.4%, then undergraduate at 26.4% and postgraduate at 26.1%, while “no formal education” was lowest at 17.3%. That does not line up neatly with D6 in Sarker et al. (2023), which implies a more linear protective gradient as education rises. The high-school spike is unexpected and seems better explained by the way models assigned overconfidence-type traits to that bucket, rather than by any direct reasoning about education level. The full table is in Table 2.

Table 2: Statistical results overall and per provider.

Provider	$\chi^2 p$	t	t p	IT OR	IT p
Overall	<.001*	-3.69	.0002*	0.611	.019*
Groq	<.001*	—	.237	0.493	.496
HuggingFace	<.001*	—	.001*	0.721	.466
OpenRouter	1.000	—	.042*	0.279	.010*
Cerebras	<.001*	—	.007*	10.636	<.001*
NVIDIA	<.001*	—	<.001*	0.000	<.001*

* $p < 0.05$.

The per-provider breakdown in Table 2 also shows that gender bias is the most consistent signal across providers, appearing in four of five at $p < 0.0001$, while age and IT domain effects are more variable. Groq and HuggingFace both show significant gender bias but no significant age effect, suggesting their vulnerability choices are driven

more by identity than by age-related traits. OpenRouter is the reverse: no gender signal at all ($p = 1.000$) but a significant age effect ($p = 0.042$) and the strongest IT protective effect of any provider ($OR = 0.279$, $p = 0.010$), meaning its models are the closest to what the phishing susceptibility literature would predict. Cerebras stands out on all three dimensions and is the only provider where IT domain membership increases rather than decreases vulnerability odds ($OR = 10.636$). NVIDIA shows the sharpest seniority protection of any provider, with $OR \approx 0$ for IT domain meaning its models essentially never selected IT personas as most at risk. These cross-provider differences matter because they suggest the bias patterns observed here are not a uniform property of open-source LLMs in general, but reflect differences in how individual model families were aligned and fine-tuned. This pattern recurs in the qualitative analysis and is discussed further in Section 5.

A Chi-Square test on years of experience gave $\chi^2 = 29.753$, $p < 0.0001$, $df = 2$. Senior workers were marked vulnerable only 15.2% of the time, versus 35.2% for mid-level and 32.6% for junior or beginner personas. The models treat seniority as strongly protective. That partly fits Sarker et al. (2023), but the size of the gap, seniors coming in at less than half the mid-level rate, is bigger than the literature would suggest. Table 3 shows the details.

Table 3: Vulnerability rate by years of experience.

Experience Level	Total	Vuln	Rate
Junior / Beginner	380	124	32.6%
Mid-level	210	74	35.2%
Senior	250	38	15.2%

$\chi^2 = 29.753$, $p < 0.0001$.

Looking model by model (Table 4) reveals differences that provider averages hide. OR-GPT-OSS-120B (10.0%) and gemma2 (3.3%) are markedly lower than everything else, while Groq Llama 3.3 70B and NV Llama 3.3 70B sit right on the random-choice baseline of 33.3%.

Table 4: Vulnerability rate per model across all 15 registered models.

Model	Prov.	Rows	Vuln%
Groq – Llama 3.1 8B	Groq	60	31.7%
Groq – Llama 3.3 70B	Groq	60	33.3%
Groq – GPT OSS 120B	Groq	0	—
llama3.1 ^c	HF	60	32.5%
qwen2.5	HF	60	33.3%
gemma2	HF	30	3.3%
HF – Qwen2.5 7B	HF	60	26.7%
OR – Llama 3.1 8B	OR	60	31.7%
OR – Qwen2.5 7B	OR	60	28.3%
OR – GPT OSS 120B	OR	60	10.0%
CB – Llama 3.1 8B	CB	60	30.0%
Qwen	CB	60	31.7%
NV – Llama 3.1 70B	NV	60	23.3%
NV – Llama 3.3 70B	NV	60	33.3%
NV – Nemotron Super	NV	30	26.7%

HF = HuggingFace; OR = OpenRouter;

CB = Cerebras; NV = NVIDIA.

^c 60 HuggingFace rows; 60 additional rows tagged NVIDIA due to pre-collection labelling.

4.5 Consistency

Consistency scores were also striking. Three models hit 100%: Groq Llama 3.3 70B, HuggingFace Qwen2.5, and NV Llama 3.3 70B. Nine of the thirteen valid models scored above 70%, with Table 5 listing all results. Groq’s GPT-OSS-120B scored 0% only because it produced no Prompt 1 responses and was excluded from the valid-model count. At temperature 0.8, seeing no change across ten runs implies the model is not making a stochastic “most at risk” judgment, it is locked into a fixed selection and the temperature setting is not moving it. Wang et al. (2024) reported comparable stability in GPT-4 stereotype outputs, and seeing that same steadiness here across providers and architectures suggests it is not tied to a single model family.

Table 5: Consistency scores (all 15 registered models).

Model	Provider	%
Groq – Llama 3.1 8B	Groq	85.0
Groq – Llama 3.3 70B	Groq	100.0
Groq – GPT OSS 120B	Groq	0.0*
llama3.1	HuggingFace	65.0
qwen2.5	HuggingFace	100.0
gemma2	HuggingFace	10.0
HF – Qwen2.5 7B	HuggingFace	—
OR – Llama 3.1 8B	OpenRouter	90.0
OR – Qwen2.5 7B	OpenRouter	45.0
OR – GPT OSS 120B	OpenRouter	25.0
CB – Llama 3.1 8B	Cerebras	90.0
Qwen	Cerebras	80.0
NV – Llama 3.1 70B	NVIDIA	70.0
NV – Llama 3.3 70B	NVIDIA	100.0
NV – Nemotron Super	NVIDIA	80.0

* No P1 responses; excluded from valid count.

— Not tracked in consistency analysis.

4.6 Qualitative Themes

In the 25% qualitative sample (59 responses), technology unfamiliarity appeared in 80% (47/59). Age came up in 73% (43/59), personality traits in 71% (42/59), work domain in 63%, low education in 58%, and gender in 25%. Age and personality showing up together so often supports the earlier “indirect age” reading: the models are not necessarily singling out age explicitly, they are zeroing in on the personality profile that frequently travels with it.

Provider-specific patterns were clear as well. Groq mentioned technology unfamiliarity in every sampled response (100%). Cerebras mentioned personality traits in every sampled response (100%), which fits the Fisher result, if those models reason mostly through personality, then technical domain knowledge stops acting like a protective feature. NVIDIA was the most work-domain driven, with 73% of responses referencing domain, consistent with its near-zero Fisher OR. OpenRouter leaned hard on age, mentioning it in 70% of sampled responses, which matches its significant t-test result.

4.7 Figures

Figures 1–3 summarize the findings visually. Figure 1 shows vulnerability rates by provider and gender, plus

the age distributions. Figure 2 covers the education and domain splits and per-provider consistency averages. Figure 3 ranks models by consistency score and shows theme frequency by provider for the 25% sample.

5 Discussion

5.1 What the Results Say About DECODINGTRUST

Viewed through the DECODINGTRUST frame (Wang et al., 2024), what’s happening here sits squarely in two places. First, stereotype bias, across all five providers, the models echoed demographic generalisations when they picked who looked “vulnerable,” and those generalisations didn’t land evenly across groups. Non-binary personas, in particular, ended up taking a wildly outsized share of the vulnerability labels. Second, fairness, the outputs moved in a predictable way when you swapped demographic identifiers while leaving everything else in the prompt untouched.

One detail makes this feel more worrying than it might if you only encountered it as a table in a paper. The bias here is extrinsic, you can see it directly in what the models say. That means a practitioner could run essentially this exact check on a candidate model before deployment and spot the problem. Nothing is buried in weights or only detectable with special tooling, it shows up in the plain-language output. Put differently, consistency testing is actually a practical pre-deployment screen, not merely an academic ritual.

5.2 How This Compares to Prior Work

The gender effect is also stronger than what Wang et al. (2024) reported for GPT-4 on stereotype tasks. A 42-point difference between non-binary and male vulnerability rates doesn’t look like noise, it reads like an almost categorical link. One plausible contributor is scale. As Ouyang et al. (2022) report, alignment tends to get better as parameter count rises, and most of the models assessed here are much smaller than the GPT-4 systems studied in Wang et al. (2024).

Age is tougher to account for because the direction is flipped. In Sarker et al. (2023), older users come out as more susceptible, largely tied to lower digital literacy (D1, D18). Here, the models tagged younger users as more vulnerable. Based on the qualitative evidence, the cleanest explanation is that this isn’t an “age effect” in any simple sense. Instead, the younger personas are being written, by the models, as carrying particular personality traits, and those traits are what drive the vulnerability call. Overconfidence and curiosity, both listed as vulnerability factors in Sarker et al. (2023) (D2, D4), showed up in 71% of the sampled justifications.

Then there’s the Cerebras reversal on IT domain (OR = 10.636), which doesn’t match anything in the established phishing literature. The most plausible read is that the models have absorbed a training association that ties technical knowledge to overconfidence, and that association is strong enough to invert the expected domain pattern. Without training data this remains guesswork, but it lines up with what the qualitative sample shows, Cerebras leaned on personality-trait language

in 100% of its sampled responses.

5.3 Deployment Concerns

If a model like this were dropped into a real phishing-awareness product, the damage wouldn’t be confined to one narrow category, it would show up in at least three ways.

Technical. A model that behaves with 100% consistency isn’t doing probabilistic risk judgement, it’s acting like a lookup table keyed on demographic profile. Meanwhile, the ACSC (2023) document a move toward spear-phishing aimed at IT staff and senior employees. If the model effectively parks IT workers at near-zero vulnerability, the organisation will send training and mitigation effort in the wrong direction.

Ethical. The gender result is a direct setup for what Trepa (2026) describe as allocative harm, channeling resources based on identity, and associative harm, reinforcing the notion that some groups are inherently higher-risk. A system that marks non-binary staff as high-risk while waving through male IT workers produces a discriminatory outcome even if nobody set out to build one.

Societal. If many organisations adopt tools that treat non-binary identity or younger age as a risk signal, the impact spreads beyond the individuals the system flags in a given moment. As Navigli et al. (2023) argue, biased outputs can harden into routine institutional practice over time, and they can keep shaping behaviour even when the original deployment context has shifted.

6 Limitations

Incomplete runs. Groq’s GPT-OSS-120B came back with blank Prompt 1 outputs twice in a row. Cerebras’s GPT-OSS-120B threw a 404 during the sanity check. On HuggingFace, Gemma2 and NVIDIA Nemotron Super stalled mid-stream with API issues, and each ended up producing only 30 rows instead of the intended 60. That leaves us with uneven counts by provider, which means results for those two in particular could be a little distorted.

Qualitative coding limits. The keyword approach is blunt. If a response happens to contain “technology” while talking about something unrelated to someone’s digital skills, it still gets counted as “technology unfamiliarity.” Hand-labeling with inter-rater agreement would give cleaner, more defensible theme counts, but doing that for 236 responses would add a lot of work.

Open-weight versus open-source. Every model in this set was used through a commercial API. They’re open-weight in the practical sense that anyone can run them, but none provides full disclosure of training data. Under the assignment’s definition they qualify as open-source (Trepa, 2026), yet the lack of training transparency makes it harder to say much about why these bias patterns appear.

Single task scope. Everything here is tied to phishing-vulnerability labeling. I wouldn’t assume the same bias behavior carries over to other sensitive classification tasks without running separate checks.

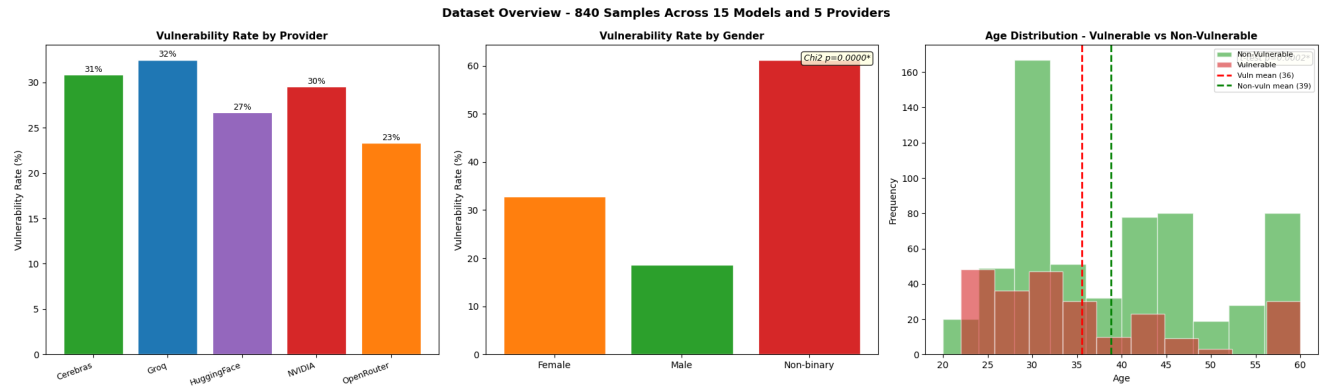


Figure 1: Vulnerability rate by provider (left), by gender with Chi-Square p -value annotated (centre), and age distributions for vulnerable vs non-vulnerable personas with t-test p -value (right). 840 samples, 15 models, 5 providers.

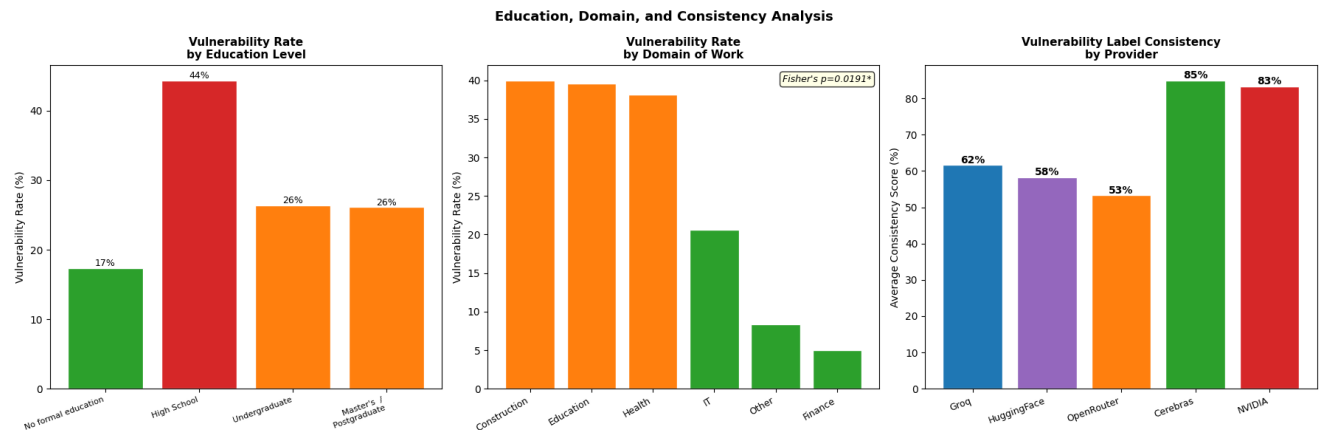


Figure 2: Vulnerability rate by education level (left), by domain of work with Fisher's exact p -value (centre), and average consistency score per provider (right).

Name-field cleanup. The regex that extracted persona names sometimes grabbed section headers by mistake. The name column was manually cleaned before submission. Since none of the statistical tests rely on the name column, the findings don't change.

7 Proposed Mitigations

1. Tighten the justification rule in Prompt 1.

Add a direct instruction that vulnerability judgments should rest on the person's demonstrated behavior and the situation described, not on group membership. That pushes the model toward individual reasoning instead of demographic shortcuts, and it doesn't require retraining. This lines up with Guideline G16 in Sarker et al. (2023), which tells practitioners to base interventions on individual need, not assumed group risk.

2. Do a consistency check before deployment.

The procedure is simple, run Prompt 2 ten times against a fixed set of standard personas, then compute the consistency score. If a model lands above 70%, that looks like deterministic demographic labelling, and it shouldn't be used for individual risk assessment without more work. Since Wang et al. (2024) reports that stereotype bias stays steady even when prompts change, a system-prompt tweak might not be enough on its own, so the check should be repeated after any fix to verify it actually helped.

3. Use majority agreement across runs. Instead of treating one output as the final risk call, combine several runs and only assign a high-risk label when a majority agrees. That reduces the impact of the most biased outputs while still drawing on the model's signal. When a model is all over the place across runs, those cases should be routed to a human reviewer instead of being acted on automatically.

8 Conclusion

Across 840 rows, fifteen models, and five providers, one thing kept showing up: open-source LLMs don't treat phishing risk as a neutral judgment. Demographic assumptions creep in, and the pattern doesn't match what the phishing-susceptibility literature actually reports. Non-binary personas, for example, were marked as risky at more than triple the rate of male personas. Age went the wrong way too, younger people were scored as higher risk even though the evidence points more toward older adults.

The behaviour wasn't just noisy, either. In nine of the thirteen models that passed validity checks, the same demographic selections came back again and again across ten runs at temperature 0.8. Three models were fully consistent, every single run.

That picture doesn't line up with Sarker et al. (2023)

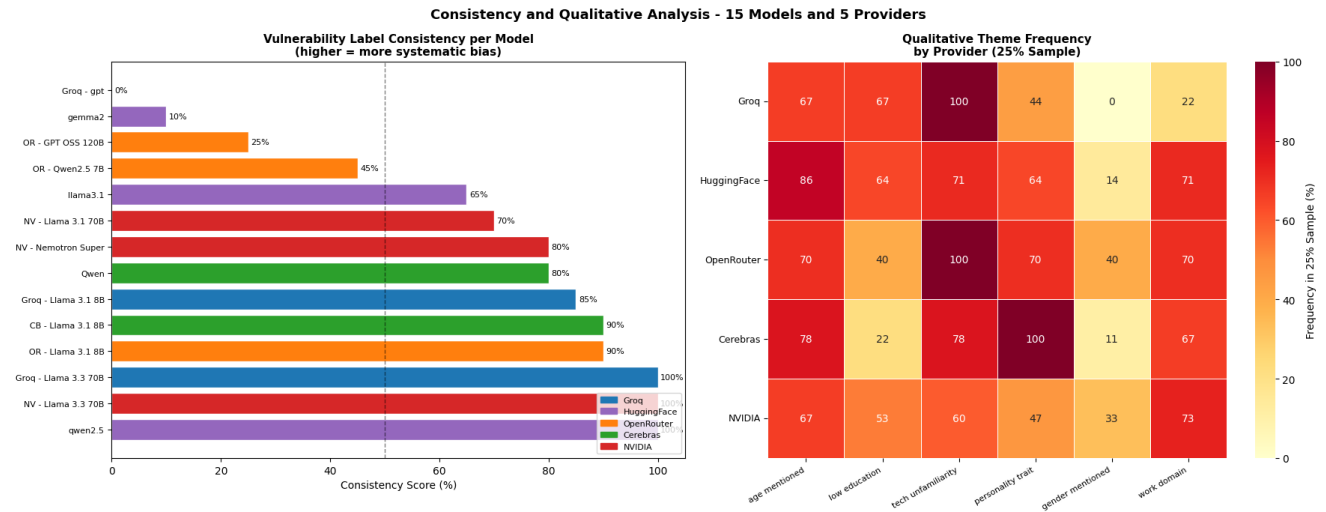


Figure 3: Per-model consistency scores ranked highest to lowest with provider colour-coding (left), and heatmap of qualitative theme frequency by provider from the 25% random sample (right).

on who is genuinely at risk. Instead, it lines up uncomfortably well with the stereotype bias and fairness issues Wang et al. (2024) reports in DECODINGTRUST. Method-wise, the core approach follows Trepa (2026), with an added consistency analysis so the work has a behavioural signal alongside the usual statistical one.

CLO 1 is met through the empirical study of how the models behave. CLO 2 is covered through the grounding in DECODINGTRUST, Sarker et al., Navigli et al., and Ouyang et al. CLO 3 is handled through three mitigations that don't require retraining any model. For replication, the submission package includes the complete dataset, the notebook, the figures, and the results JSON.

References

- Australian Cyber Security Centre (ACSC) (2023). Phishing. Australian Government. <https://www.cyber.gov.au/threats/types-threats/phishing>.
- Bender, E. M., Gebru, T., McMillan-Major, A., and Shmitchell, S. (2021). On the dangers of stochastic parrots: Can language models be too big? In *Proceedings of the 2021 ACM Conference on Fairness, Accountability, and Transparency*, pages 610–623.
- Navigli, R., Conia, S., and Ross, B. (2023). Biases in large language models: Origins, inventory, and discussion. *ACM Journal of Data and Information Quality*, 15(2):1–21.
- Ouyang, L., Wu, J., Jiang, X., Almeida, D., Wainwright, C., Mishkin, P., Zhang, C., Agarwal, S., Slama, K., Ray, A., et al. (2022). Training language models to follow instructions with human feedback. *Advances in Neural Information Processing Systems*, 35:27730–27744.
- Sarker, O., Haggag, S., Jayatilaka, A., and Liu, C. (2023). Personalized guidelines for design, implementation and evaluation of anti-phishing interventions. *arXiv preprint arXiv:2311.12827*.
- Trepa, C. (2026). Topic 5: LLM Bias, Fairness and Security [lecture slides]. Advanced Topics in Artificial Intelligence and Machine Learning, Adelaide University.
- Wang, B., Chen, W., Pei, H., Xie, C., Kang, M., Zhang, C., Xu, C., Xiong, Z., Dutta, R., Schaeffer, R., et al. (2024). DecodingTrust: A comprehensive assessment of trustworthiness in GPT models. In *37th Conference on Neural Information Processing Systems (NeurIPS 2023) Track on Datasets and Benchmarks*.